INFORMATION SECURITY · INFOGRAPHIC

SOCIAL ENGINEERING

ATTACKS & MAJOR SECURITY BREACHES

Real-world case studies · Attack techniques · Prevention strategies

PHISHING

PRETEXTING

BAITING



Student submission · 2026

01 · THE THREAT

The Human Attack Surface

What is social engineering?

Hacking people instead of computers. Attackers manipulate victims into revealing credentials, clicking malware, or granting access — walking straight past firewalls, antivirus and encryption.

WHY IT WORKS

Trust bias — we instinctively help people who sound legitimate

Authority — "I'm from IT security, verify your account now"

Urgency & fear — panic short-circuits the habit of double-checking

68%

of breaches involve a human element — phishing, errors or stolen creds

VERIZON DBIR 2024

$4.88M

average cost of a single data breach worldwide

IBM COST OF BREACH 2024

3.4B

phishing emails are estimated to be sent every single day

INDUSTRY ESTIMATE

02 · THE TOOLKIT

Six Ways They Get In



TECH 01

Phishing

Mass fake emails spoofing trusted brands to steal logins or deliver malware.



TECH 02

Spear Phishing

A highly targeted email, crafted with real personal details about you.



TECH 03

Vishing

Voice phishing — urgent “bank” or “support” calls pressuring you to act.



TECH 04

Pretexting

An invented scenario — “IT audit”, “CEO request” — that extracts data.



TECH 05

Baiting

Curiosity traps: infected USB sticks, fake free downloads, juicy offers.



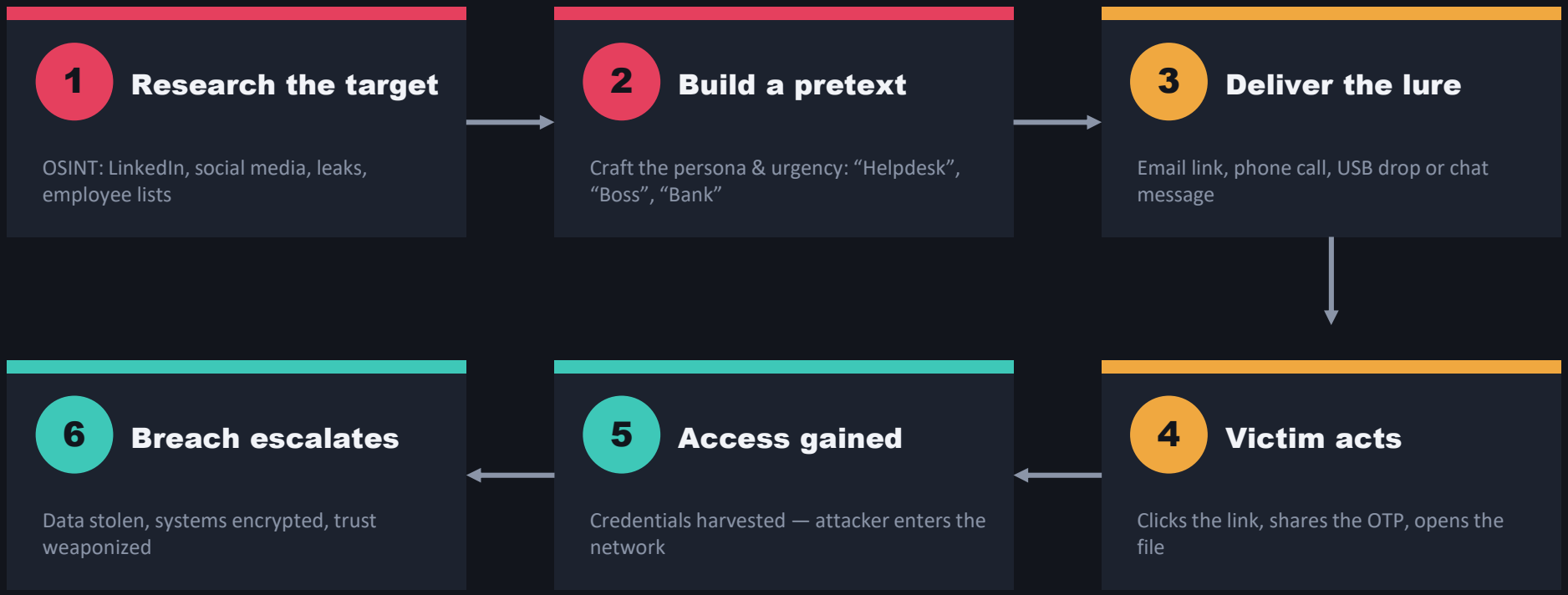
TECH 06

Tailgating

Slipping into a secure area right behind an authorized badge holder.

03 · THE KILL CHAIN

Anatomy of a Social Engineering Attack



Every major breach on the next pages walks this exact chain — **6 steps from stranger to breach.**

Breach Case Studies — Social at Scale

JULY 2020

Twitter

⚠ PHONE SPEAR-PHISHING (VISHING)

What happened

- Attackers posed as Twitter IT on calls to employees
- "VPN issue" story convinced staff to share logins
- Admin panel used to hijack 130 verified accounts
- Obama, Musk, Gates accounts pushed a bitcoin scam

130 high-profile accounts hijacked — ~$121K bitcoin collected by the scam

SEP 2023

MGM Resorts

⚠ VISHING THE IT HELP DESK

What happened

- Scattered Spider researched an employee on LinkedIn
- Impersonated them in a call to the IT help desk
- Talked staff into a password + MFA reset on the spot
- Super-admin Okta access → hotels & casinos offline

~$100M estimated losses — MGM operations disrupted for days

04 · CASE FILES

Breach Case Studies — One Email Away

NOV 2013

Target

⚠ PHISHING OF A VENDOR (Fazio Mechanical)

What happened

- Malware-laden email hit Fazio, Target's HVAC vendor
- Stolen vendor credentials opened the supplier portal
- Attackers pivoted into card-payment systems
- PoS malware skimmed cards for weeks, undetected

40M payment cards skimmed — plus 70M customer records exposed

MAR 2011

RSA Security

⚠ PHISHING + ZERO-DAY (EXCEL FILE)

What happened

- Employees got an email: “2011 Recruitment plan.xls”
- Opening it triggered a zero-day Flash exploit
- Attacker planted backdoor, reached SecurID systems
- Token seed data stolen — the company's crown jewels

1 malicious attachment was all it took to compromise the world's security leader

Case 5 — The MFA Fatigue Attack

NOV 2022

Uber

⚠ STOLEN PASSWORD + MFA FATIGUE (VISHING STYLE)

What happened

- Contractor's password bought on the dark-web (stolen by infostealer malware)
- MFA push notifications spammed until the contractor accepted one
- Attacker posed as Uber IT over chat — “accept the prompt to stop them”
- Admin credentials found in plain text inside internal network scripts
- AWS, Slack, Google Drive, vSphere and bug-bounty systems all reached

Root cause: a single human moment — one accepted push notification.

1 push

one accepted MFA prompt opened the entire company

570+

customer & driver records exposed in the breach

6 systems

AWS · Slack · Drive · vSphere · VPN · HackerOne

05 · LESSONS

How Each Breach Could Have Been Prevented

Twitter 2020 Phone vishing → admin panel	Hardware security keys for all staff; no phone-based resets for privileged tools
MGM 2023 Help-desk vishing → Okta admin	Strict help-desk verification (callback to registered number); least-privilege admin rights
Target 2013 Vendor phishing → payment network	Vendor least-privilege & network segmentation; malware filtering at the email gateway
RSA 2011 Excel attachment → token theft	Block/inspect Office attachments; prompt patching; staff trained to report odd emails
Uber 2022 MFA fatigue → VPN & cloud systems	Number-matching or phishing-resistant MFA; auto-reset stolen passwords; no secrets in scripts

06 · DEFENSE

The Prevention Toolkit

Verify before you trust

Call back on a known number — never the one the caller gave you.

MFA everywhere

Prefer hardware keys (FIDO2) — they beat phishing kits every time.

Least privilege

One compromised account should never unlock everything.

Train & simulate

Regular phishing drills turn staff into the human firewall.

Report fast

One click to report suspicious mail — seconds save a breach.

Patch & segment

Updated software and isolated networks stop small leaks growing.

“The strongest firewall is a skeptical human.”